

CCG Remediation TODO

Prioritized backlog from the 2026-09-18 deep review

Tackle in order; each item cites its finding ID

- [How to read this](#)
 - [P0 — Must fix before ANY enforcement-mode \(ENFORCE \) deploy](#)
 - [P1 — Correctness & security \(before feature-complete\)](#)
 - [P2 — Hygiene, docs, and CI](#)
 - [Suggested sequencing](#)
 - [Traceability](#)

How to read this

Ordered by **risk-to-unblock ratio**: fixes that gate the enforcement-mode deploy come first, then correctness, then hygiene. Each item lists the finding ID, the concrete action, the files, and a “done when” acceptance check. Nothing here is deployed, so all of this is pre-deployment hardening — the ideal time to do it.

Legend:  blocks enforcement deploy ·  correctness/security ·  hygiene/docs

P0 — Must fix before ANY enforcement-mode (ENFORCE) deploy



 **P0.1 (C1) Correct the LOG_ONLY framing everywhere and re-state the real capture-safety basis.**

- Edit `modules/agentcore-gateway/main.tf`, `docs/THREAT_MODEL.md`, `docs/DEPLOY_RUNBOOK.md`: `LOG_ONLY = evaluates but does not enforce`; capture is safe **only because no permits exist**, not because forbids enforce.
- **Done when:** no doc/comment claims `LOG_ONLY` is fail-closed; the deploy runbook’s gate explicitly states “zero permits present” as the safety basis.



 **P0.2 (C1) Design the enforcement activation correctly.** Enforcement needs `mode = "ENFORCE"` + a committed default-deny Cedar policy set, flipped only via the audited activation flow, and only after T2 (P0.4) is resolved.

- **Done when:** an ADR records the ENFORCE activation sequence; `remediation-permits.cedar` has a reviewed default-deny baseline; `enable_agentcore_gateway` stays `false` until then.



 **P0.3 (C2) Close the production enforcement gap.** `AgentCoreGatewayClient` must not be a blind pass-through in an ENFORCE world. Add an integration seam that asserts forbid-overrides-permit/default-deny against the real transport; share one invoke skeleton between the

double and prod so they cannot diverge; implement the activation→enforcement propagation that today only exists as the demo's manual `gateway.activate_permits` bridge.

- **Done when:** there is a test exercising the real transport path (or a faithful emulator), and no “green” claim rests solely on `InMemoryCedarGateway`.



● **P0.4 (M2/T2) Resolve how safety attributes reach Cedar and validate tool+params server-side.** Capture the live request-context shape (gate-0.2 §2); confirm the caller cannot self-assert `CCGDemo / Environment`. In `api.py`, derive/validate the `tool` and a bounded parameter set from the finding's `rule_id`; reject mismatches.

- **Done when:** `AGENTCORE_CAPABILITY_RECORD.md` §2 is filled; `api.py` rejects a command whose tool/params are inconsistent with the resolved finding, with a test.

P1 — Correctness & security (before feature-complete)



● **P1.1 (H3) Make idempotency payload-bound and never cache failures.** Key on a hash of `(tool, target_arn, sorted params, expected_finding_version)`; reject reused key + changed payload; only cache `APPLIED / NOOP`. Specify + test on the real transport.



● **P1.2 (H4) Add `update_policy_set` to `PolicyControlPlaneTransport`.** Prevents the activation-path `AttributeError`; make generation-based concurrency the single source of truth; remove/durable-ize the in-memory `request_id` cache.



● **P1.3 (H1) Fix IAM tag-gating.** Scope S3 remediation by explicit bucket ARNs (not `arn:aws:s3:::*` + unenforceable tag); verify every tool action against the IAM condition-key reference; split unscopable reads. Update the “no bare `*`” comment to the truth.



● **P1.4 (H2) Wire observability or downgrade the claims.** Inject `MetricSink` through discovery/gateway/policy/reconcile/audit and emit at each decision/outcome with emission tests — or mark every threat-model `Metric:` line and CCG-REQ-037 as “planned.”



● **P1.5 (M1) Bind reconcile resolution to real evidence.** `confirm_from_discovery` should take a discovery-run correlation/evidence ref and verify it came from a completed, non-partial run before resolving.



● **P1.6 (M3) Deep-freeze contract Mappings** (or document + enforce the immutability invariant) so nested `parameters / attributes / details` can't be mutated post-construction.



● **P1.7 (M6) Harden the audit bucket.** Pin SSE algorithm via `StringNotEquals` deny; add `aws_s3_bucket_logging`.



● **P1.8 (M7) Improve audit redaction.** Add value-pattern redaction (AKIA..., PEM, JWT); stop clobbering `AccessKeyId`; recurse list elements with parent-key context.



● **P1.9 (M4) Default DynamoDB `enable_deletion_protection = true`**; teardown flips it off explicitly.

P2 — Hygiene, docs, and CI

☐

● **P2.1 (M8) Pin a real Terraform version in CI** (consistent with `versions.tf`).

☐

● **P2.2 (M9) Reconcile documentation.** One source of truth for the test count (117); fix `TEST_TRACEABILITY` logging (CCG-REQ-034) and alarms (CCG-REQ-037) rows to reflect reality (no logging subsystem; metrics unwired).

☐

● **P2.3 (M5) Record the AWS-managed-keys decision as an ADR** with the explicit no-CMK / no-key-audit-trail consequence.

☐

● **P2.4 (L1) Add ADRs** for Cedar-first, LOG_ONLY posture, dry-run rotation, provider pin, Python 3.14, HCP OIDC. (*Started in this change set.*)

☐

● **P2.5 (L2) Console:** drive activation version from server state (remove hardcoded `"v1"`); render decision evidence; add console tests.

☐

● **P2.6 (L3) Rewrite README** — state “planning-stage POC, nothing deployed”; fix the `terraform -chdir=terraform` path; point to `python -m ccg.demo`. (*Addressed in this change set.*)

☐

● **P2.7 (M-tf) Add** `required_providers` **to each submodule**; enable the tflint `terraform` ruleset (`preset = "recommended"`).

☐

● **P2.8 (L4) Add** `aws:SourceArn` to the gateway assume-role once the Gateway ARN is known.

☐

● **P2.9 (L5) Mark policy-JSON root outputs** `sensitive = true`.

Suggested sequencing

1. **This change set** (docs/ADRs/diagrams/README) clears P2.4 and P2.6 and documents C1 honestly.
2. **Next PR:** P0.1 (framing) + P2.2 (doc reconciliation) — pure documentation truth, no code risk.
3. **Then** P1.1–P1.9 correctness fixes (each its own PR, TFC-validated).
4. **Only then** P0.2/P0.3/P0.4 — the enforcement design — gated on the live gate-0.2 capture.
5. Enforcement-mode deploy last, via reviewed HCP plan.

Traceability

Full evidence and severity rationale: `docs/review/CCG_REVIEW_REPORT.md`. Behavioral analysis: `semantic-review/2026-09-17-213032-pr-all.md`.